CRISC Domain D - 100 More Impossible Hard Questions

Information Technology and Security - Expert Level Part 4

CRISC Mastery Series

October 24, 2026

Warning

Extreme Difficulty

Domain D is technical but the exam tests judgment, not trivia.
Every option will look plausible.
Think like a risk practitioner advising on technology, not a technician.

Outline

1. 1. Enterprise Architecture
2. 2. IT Operations and Change Management
3. 3. Enterprise Resiliency
4. 4. Data Lifecycle Management
5. 5. SDLC and Emerging Technologies
6. 6. Information Security Principles

Q301: Architecture Principle Enforcement

Question

A project manager claims an architecture principle does not apply to their project. What is the BEST governance response?

A. Ignore the claim

B. Require documented analysis and approval through the architecture review or exception process

C. Proceed without review

D. Cancel the project

Q301: Explanation

Correct Answer: B

Claims need governance review:

- Principles apply by default
- Exemptions require review
- Documentation protects decisions

Critical Trap

Principle exemptions need governance, not assertion.

Q302: Architecture Roadmap Risk

Question

What is the MAIN risk of an outdated EA roadmap?

- A It looks old
- B It drives investment toward obsolete or misaligned states
- C It costs more
- D It is too detailed

Q302: Explanation

Correct Answer: B

Stale roadmaps misalign investment:

- Guides investment
- Outdated guides wrongly
- Review regularly

Critical Trap

Stale roadmaps cause misallocation.

Q303: Business Capability Mapping

Question

What is the purpose of business capability mapping?

- A Marketing
- B Describe what the business can do independent of organizational structure
- C Reduce staff
- D Buy tools

Q303: Explanation

Correct Answer: B

Capabilities describe what business can do:

- Business outcomes
- Stable view
- Independent of structure

Critical Trap

Capabilities describe business outcomes, not org charts.

Q304: Architecture Compliance Review

Question

What should an architecture compliance review verify?

A. Only cost

B. Alignment with principles, standards, and target architecture

C. Only vendor logos

D. Only timelines

Q304: Explanation

Correct Answer: B

Compliance means alignment:

- Principles
- Standards
- Target architecture

Critical Trap

Compliance review is alignment, not cost check.

Q305: Application Rationalization

Question

What is the main benefit of application rationalization?

- A More apps
- B Reduced duplication, cost, and complexity
- C Higher licensing
- D Better visuals

Q305: Explanation

Correct Answer: B

Rationalization reduces duplication:

- Consolidate overlapping apps
- Retire low-value systems
- Lower cost and complexity

Critical Trap

Rationalization reduces cost and complexity.

Q306: Architecture Principle Characteristics

Question

Which is a characteristic of a good architecture principle?

A. Vague
B. Understandable, relevant, and actionable
C. Extreme
D. Optional

Q306: Explanation

Correct Answer: B

Good principles are clear and actionable:

- Understandable
- Relevant
- Actionable

Critical Trap

Vague principles are unusable.

Q307: Architecture Debt Visibility

Question

Why should architecture debt be visible to leadership?

A. It looks bad

B. It affects cost, risk, and speed of change

C. It is entertainment

D. It is optional

Q307: Explanation

Correct Answer: B

Debt affects business outcomes:

- Costs
- Risk
- Change speed

Critical Trap

Hidden debt becomes a business surprise.

Q308: EA and Merger Integration

Question

What is the role of EA in a merger integration?

A. Ignore
B. Guide consolidated target architecture and integration priorities
C. Marketing
D. Payroll

Q308: Explanation

Correct Answer: B

EA guides integration:

- Consolidate architectures
- Sequence priorities
- Reduce duplication

Critical Trap

M&A integration needs EA direction.

Q309: Architecture Governance Escalation

Question

If an architecture decision cannot be resolved at the working level, what should happen?

A. Ignore it

B. Escalate to appropriate governance authority

C. Pick randomly

D. Cancel

Q309: Explanation

Correct Answer: B

Escalation is a control:

- Defined escalation path
- Authority resolves
- Documented outcome

Critical Trap

Unresolved decisions stall projects.

Q310: EA Value Communication

Question

How should EA value be communicated to business leaders?

- A Technical diagrams only
- B Business outcomes enabled, cost savings, and reduced risk
- C Vendor names
- D Only budgets

Q310: Explanation

Correct Answer: B

Speak business outcomes:

- Outcomes
- Savings
- Risk reduction

Critical Trap

Business leaders want outcomes, not diagrams.

Q311: Change Risk Assessment

Question

What should a change risk assessment evaluate?

A. Only cost
B. Business impact, likelihood of failure, and dependencies
C. Only vendor names
D. Only deadlines

Q311: Explanation

Correct Answer: B

Assess impact and likelihood:

- Business impact
- Failure likelihood
- Dependencies

Critical Trap

Change risk = impact times likelihood.

Q312: Standard Change Model

Question

What is a standard change?

- A. A new emergency
- B. A pre-approved, low-risk, repeatable change
- C. A vendor change
- D. A cancelled change

Q312: Explanation

Correct Answer: B

Standard changes are pre-approved:

- Pre-approved
- Low risk
- Repeatable

Critical Trap

Standard changes skip per-change approval.

Q313: CAB Emergency Path

Question

What CAB mechanism supports urgent changes?

A. Ignore
B. Emergency change process with retrospective review
C. Remove CAB
D. Proceed without records

Q313: Explanation

Correct Answer: B

Emergency with retrospective:

- Emergency path
- Retrospective review
- Documented

Critical Trap

Emergency still requires governance.

Q314: Release Risk

Question

Which factor MOST affects release risk?

A. Release time
B. Number and complexity of changes in the release
C. Vendor logo
D. Marketing

Q314: Explanation

Correct Answer: B

Release risk from volume and complexity:

- Volume of changes
- Complexity
- Dependencies

Critical Trap

Release risk rises with change volume and complexity.

Q315: Incident Priority

Question

Which factor drives incident priority in ITIL?

A. Marketing
B. Impact and urgency combined
C. Number of meetings
D. Vendor discounts

Q315: Explanation

Correct Answer: B

Priority from impact and urgency:

- Impact
- Urgency
- Combined priority

Critical Trap

Priority = impact plus urgency.

Q316: Problem vs Incident

Question

What is the main output of problem management?

- A Faster restore only
- B Known errors and permanent fixes to remove root causes
- C New tickets
- D More vendors

Q316: Explanation

Correct Answer: B

Problem management reduces recurrence:

- Root causes
- Known errors
- Permanent fixes

Critical Trap

Problem management eliminates recurrence.

Q317: Knowledge Management Value

Question

Why is knowledge management valuable in IT operations?

- A Marketing
- B Reduces resolution time and improves consistency by documenting solutions
- C Reduces cost only
- D Removes staff

Q317: Explanation

Correct Answer: B

Knowledge management improves resolution:

- Documented solutions
- Faster resolution
- Consistent handling

Critical Trap

Knowledge management scales operations.

Q318: Service Catalog Purpose

Question

What is the purpose of a service catalog?

A. Marketing

B. A structured list of services offered with descriptions and SLAs

C. Employee records

D. Budgets

Q318: Explanation

Correct Answer: B

Service catalog lists services:

- Structured list
- Descriptions
- SLAs

Critical Trap

Service catalog is the front door to IT.

Q319: Capacity Management

Question

What is the purpose of capacity management?

A. Marketing

B. Ensure IT resources meet current and future demand at acceptable cost

C. Reduce headcount

D. Increase cost

Q319: Explanation

Correct Answer: B

Capacity meets demand:

- Current demand
- Future demand
- Acceptable cost

Critical Trap

Capacity management prevents surprises.

Q320: Availability Management

Question

What does availability management aim to deliver?

A. Marketing

B. Agreed availability targets aligned to business needs

C. Higher cost

D. Fewer tickets

Q320: Explanation

Correct Answer: B

Availability matches business needs:

- Availability targets
- Business alignment
- Measured

Critical Trap

Availability is about meeting business expectations.

Q321: DR Plan Scope

Question

What should a disaster recovery plan define?

- A Only backups
- B Roles, procedures, recovery steps, and communication for IT recovery
- C Only vendor names
- D Only budgets

Q321: Explanation

Correct Answer: B

DR plan defines recovery:

- Roles
- Procedures
- Steps
- Communication

Critical Trap

DR plan focuses on IT recovery, not just backups.

Q322: BCP vs DR Scope

Question

Which statement is correct?

A. BCP and DR are the same
B. BCP covers the business broadly; DR covers IT recovery
C. DR covers the business broadly
D. BCP only covers servers

Q322: Explanation

Correct Answer: B

BCP broader than DR:

- BCP is business-wide
- DR is IT-focused
- DR supports BCP

Critical Trap

BCP is business-wide; DR is one component.

Q323: Crisis Communication Plan

Question

Why is a crisis communication plan essential?

- A Marketing
- B Provides coordinated and timely communication to stakeholders during disruption
- C Reduces cost
- D Avoids audits

Q323: Explanation

Correct Answer: B

Communication under crisis:

- Coordinated
- Timely
- Stakeholders informed

Critical Trap

Crisis communication protects trust.

Q324: Third-Party BCP Dependency

Question

Why should third-party BCP dependencies be assessed?

- A Trust only
- B Verify providers can meet recovery needs aligned to your RTO and RPO
- C Cheaper
- D Faster

Q324: Explanation

Correct Answer: B

Verify alignment:

- RTO alignment
- RPO alignment
- Contracts plus verification

Critical Trap

Contracts do not guarantee recovery.

Q325: DR Exercise Types

Question

Which exercise type provides the HIGHEST assurance?

- A Tabletop
- B Full failover with real workloads
- C Document review
- D Walkthrough only

Q325: Explanation

Correct Answer: B

Full failover = highest assurance:

- Real failover
- Real workloads
- Higher cost

Critical Trap

Full failover tests real recovery.

Q326: Backup Testing Frequency

Question

Why should backup restores be tested regularly?

- A Cost only
- B Confirm recovery works and backups are not corrupted
- C To satisfy marketing
- D Ignore

Q326: Explanation

Correct Answer: B

Restore tests confirm capability:

- Recovery works
- Data is intact
- Cadence agreed

Critical Trap

Backups without restore testing are unreliable.

Q327: Cloud DR Trade-offs

Question

What is the main trade-off in cloud DR?

A. Free vs paid
B. Cost vs recovery speed and capacity
C. Only latency
D. Only firewalls

Q327: Explanation

Correct Answer: B

Cost vs speed:

- Lower RTO means higher cost
- Capacity trade-offs
- Match to business

Critical Trap

Faster recovery costs more.

Q328: BC Plan Ownership

Question

Who should own the business continuity plan?

- A IT only
- B Business leaders with IT support
- C Vendor
- D Auditor

Q328: Explanation

Correct Answer: B

Business owns BCP:

- Business owners
- IT supports
- Accountability aligned

Critical Trap

BCP is a business plan, not an IT plan.

Q329: Crisis Decision Rights

Question

What is the best practice for crisis decision rights?

- A No rights
- B Predefined crisis roles, thresholds, and escalation paths
- C Everything to the board
- D Random

Q329: Explanation

Correct Answer: B

Predefine crisis rights:

- Predefined roles
- Thresholds
- Escalation paths

Critical Trap

Clarity enables timely crisis action.

Q330: Recovery Objective Alignment

Question

Why must RTO and RPO be agreed with business owners?

A. Marketing

B. Owners understand business impact and acceptable loss

C. Cheaper

D. Faster

Q330: Explanation

Correct Answer: B

Owners define impact:

- Business impact
- Acceptable loss
- Owner-defined objectives

Critical Trap

RTO and RPO are business decisions.

Q331: Data Classification Owner

Question

Who classifies data?

- A Auditor
- B Data owner or steward
- C Vendor
- D User

Q331: Explanation

Correct Answer: B

Owners classify:

- Owners classify
- Custodians enforce
- Auditors verify

Critical Trap

Owners classify; custodians implement.

Q332: Data Labeling Purpose

Question

Why is labeling data important?

A. Marketing

B. Enables correct handling and controls based on sensitivity

C. Slower

D. Bigger files

Q332: Explanation

Correct Answer: B

Labels enable controls:

- Makes classification actionable
- Supports DLP
- Guides handling

Critical Trap

Labels make classification operational.

Q333: Retention Legal Conflict

Question

What should happen if a retention schedule conflicts with a regulator's request?

A. Destroy data
B. Follow legal guidance and preserve as required
C. Ignore
D. Archive indefinitely

Q333: Explanation

Correct Answer: B

Legal obligations over schedule:

- Legal holds or requests
- Preserve
- Document rationale

Critical Trap

Regulatory requests override retention schedules.

Q334: Data Destruction Standards

Question

Which standards best support secure destruction?

A. Marketing
B. NIST 800-88, ISO 21964, and industry standards
C. Only deleting files
D. Only formatting

Q334: Explanation

Correct Answer: B

Use standards:

- NIST 800-88
- ISO 21964
- Industry methods

Critical Trap

Deleting or formatting is not destruction.

Q335: Data Minimization Benefit

Question

What is the main benefit of data minimization?

A. Marketing

B. Reduces exposure, cost, and compliance burden

C. Faster

D. Slower

Q335: Explanation

Correct Answer: B

Less data, less risk:

- Reduced exposure
- Lower cost
- Simpler compliance

Critical Trap

Data minimization reduces risk and cost.

Q336: DSR Response Accuracy

Question

What should accompany a response to a data subject access request?

A. Only data
B. Clear information about the processing and rights
C. Marketing
D. Nothing

Q336: Explanation

Correct Answer: B

Include context:

- What was processed
- Purpose
- Rights

Critical Trap

DSAR needs transparent explanation.

Q337: Data Residency in Backup

Question

Why do backups need data residency alignment?

A. Faster

B. Backups often contain sensitive data subject to residency laws

C. Cheaper

D. Only policy

Q337: Explanation

Correct Answer: B

Backups are data:

- Sensitive data in backups
- Residency applies
- Contracts must align

Critical Trap

Backups must respect data residency laws.

Q338: Data Masking in Testing

Question

Why is masking important for non-production testing?

A. Speed only

B. Protects sensitive production data used in test environments

C. Cheaper

D. Less storage

Q338: Explanation

Correct Answer: B

Masking protects sensitive data:

- Production data in tests
- Lower controls in tests
- Mask PII and PHI

Critical Trap

Test environments often leak unmasked production data.

Q339: Data Steward Responsibilities

Question

Which is a data steward responsibility?

- A Firewall management
- B Data quality, metadata, and adherence to data policy
- C HR
- D Marketing

Q339: Explanation

Correct Answer: B

Stewardship = quality and policy:

- Quality
- Metadata
- Policy adherence

Critical Trap

Stewards focus on data, not systems.

Q340: Data Retention Metrics

Question

Which metric BEST reflects retention compliance?

A. Number of meetings
B. Percentage of data destroyed per schedule
C. Marketing spend
D. Vendor count

Q340: Explanation

Correct Answer: B

Destruction per schedule:

- Destruction performed per schedule
- Exception review
- Proof of compliance

Critical Trap

Over-retention is a compliance risk.

Q341: DevSecOps Culture

Question

What cultural change is required for DevSecOps?

- A Security only after deploy
- B Shared responsibility for security across dev, security, and ops
- C Fewer tools
- D More meetings

Q341: Explanation

Correct Answer: B

Shared responsibility:

- Shared responsibility
- Automation
- Early feedback

Critical Trap

DevSecOps is a culture shift, not a tool.

Q342: Supply Chain Software Risk

Question

Which is a growing software supply chain risk?

A. Marketing
B. Malicious or vulnerable third-party dependencies
C. Larger hard drives
D. Faster networks

Q342: Explanation

Correct Answer: B

Dependency risk:

- Open-source dependencies
- Malicious packages
- SBOM helps

Critical Trap

Supply chain software risk is growing.

Q343: SBOM Purpose

Question

What is an SBOM?

A. Marketing report

B. Software Bill of Materials listing components

C. Budget

D. Vendor logo

Q343: Explanation

Correct Answer: B

SBOM lists components:

- Components and versions
- Supports incident response
- Increasingly required by customers

Critical Trap

SBOMs speed vulnerability response.

Q344: IaC Scanning

Question

Why scan Infrastructure as Code?

A. Aesthetics

B. Detect misconfigurations and embedded secrets before deployment

C. Faster

D. Bigger files

Q344: Explanation

Correct Answer: B

Catch issues early:

- Misconfigurations
- Secrets in code
- Prevent drift

Critical Trap

IaC scanning prevents scaled misconfigurations.

Q345: Container Runtime Security

Question

Why is container runtime monitoring needed if images are scanned?

A. Cheaper

B. Detects threats that appear after deployment

C. Faster

D. Slower

Q345: Explanation

Correct Answer: B

Image scanning is snapshot:

- Image scanning is point-in-time
- Runtime threats appear later
- Monitoring closes gap

Critical Trap

Scan at build, monitor at runtime.

Q346: API Authentication Strength

Question

Which is the STRONGEST API authentication approach?

A. Basic auth in URL

B. OAuth 2.0 with short-lived tokens and audience restrictions

C. Shared secret in code

D. No auth

Q346: Explanation

Correct Answer: B

OAuth 2.0 with short tokens:

- Short-lived tokens
- Audience restriction
- Least privilege

Critical Trap

Basic auth is weakest; use OAuth 2.0.

Q347: Mobile Rooting Risk

Question

Why does device rooting or jailbreaking increase risk?

A. Bigger screen

B. Removes OS security controls and enables unauthorized access

C. More apps

D. Bigger battery

Q347: Explanation

Correct Answer: B

Rooting removes controls:

- Removes OS security controls
- Bypasses sandboxing
- Increases malware risk

Critical Trap

Rooted devices are riskier.

Q348: Zero-Trust Policy Engine

Question

What role does a policy engine play in Zero Trust?

- A Marketing
- B Evaluates context and enforces access decisions
- C Stores backups
- D Filters email

Q348: Explanation

Correct Answer: B

Policy engine enforces access:

- Context evaluation
- Access decisions
- Enforced dynamically

Critical Trap

Zero Trust needs a policy engine for consistent decisions.

Q349: Post-Quantum Readiness Steps

Question

What is the FIRST step in post-quantum readiness?

A. Replace all systems

B. Inventory cryptographic assets and dependencies

C. Ignore

D. Buy tools

Q349: Explanation

Correct Answer: B

Inventory first:

- Crypto inventory
- Dependencies
- Migration planning

Critical Trap

Quantum readiness begins with inventory.

Q350: AI Model Monitoring

Question

Why must AI models be monitored after deployment?

- A Cost only
- B Data drift and behavior changes can reduce accuracy and introduce bias
- C To satisfy marketing
- D To delete models

Q350: Explanation

Correct Answer: B

Models drift:

- Data drift
- Behavioral changes
- Bias emergence

Critical Trap

Model monitoring is essential after deployment.

Q351: Non-Repudiation Evidence

Question

Which control provides the STRONGEST non-repudiation?

- A Password
- B Digital signature with immutable logs
- C Session cookie
- D Firewall rule

Q351: Explanation

Correct Answer: B

Signatures and logs support proof:

- Signed with private key
- Logged immutably
- Provides proof

Critical Trap

Non-repudiation requires cryptographic proof.

Q352: TLS Termination Risk

Question

What is the risk of terminating TLS at a load balancer without re-encryption?

A. Slower
B. Traffic between load balancer and backend may be exposed
C. Cheaper
D. Faster

Q352: Explanation

Correct Answer: B

Re-encrypt or segment:

- Exposed backend
- Re-encrypt or segment
- Verify with threat model

Critical Trap

TLS termination exposes backend if not re-encrypted.

Q353: Certificate Transparency

Question

What does certificate transparency provide?

A. Marketing
B. Public logs enabling detection of misissued certificates
C. Bigger certificates
D. Cheaper TLS

Q353: Explanation

Correct Answer: B

Public logs detect misissuance:

- Public logs
- Detect misissuance
- Early warning

Critical Trap

Certificate Transparency helps detect fraud.

Q354: HSM Tamper Resistance

Question

Why does an HSM provide stronger protection for keys than a server?

A. Bigger keys

B. Tamper-resistant hardware, keys never leave in plaintext

C. Cheaper

D. Faster

Q354: Explanation

Correct Answer: B

Tamper resistance:

- Tamper-resistant
- Keys do not leave
- Operations inside

Critical Trap

HSMs protect keys even if host is compromised.

Q355: Symmetric vs Asymmetric Use

Question

Which is a correct statement?

A. Symmetric is used for key exchange only

B. Asymmetric is used for key exchange; symmetric for bulk encryption

C. Asymmetric for bulk

D. Neither

Q355: Explanation

Correct Answer: B

Common hybrid scheme:

- Asymmetric for key exchange
- Symmetric for bulk
- Common hybrid scheme

Critical Trap

Asymmetric establishes; symmetric encrypts bulk.

Q356: Digital Signature Verification

Question

Which key is used to verify a digital signature?

A. Sender private key
B. Sender public key
C. Receiver private key
D. Receiver public key

Q356: Explanation

Correct Answer: B

Sender public key:

- Verified with sender public key
- Signed with sender private key
- Proves origin

Critical Trap

Verify with sender public key.

Q357: Access Review Metrics

Question

Which metric shows access review effectiveness?

A. Number of meetings
B. Percentage of access reviewed and revoked where not needed
C. Vendor count
D. Budget

Q357: Explanation

Correct Answer: B

Review completion plus revocation:

- Review completion
- Revocation
- Reduced access creep

Critical Trap

Reviews without revocations do little.

Q358: UEBA False Positive Risk

Question

What is the main risk of poorly tuned UEBA?

A. Too few alerts
B. Alert fatigue from false positives
C. Slower system
D. Smaller logs

Q358: Explanation

Correct Answer: B

Tune to reduce noise:

- False positives
- Alert fatigue
- Tuning essential

Critical Trap

Untuned UEBA causes alert fatigue.

Q359: Federation Trust Risk

Question

What is the primary risk in identity federation?

A. Slower logins

B. Compromise of a federation partner can grant access to your systems

C. Cheaper

D. More tools

Q359: Explanation

Correct Answer: B

Federation partner trust:

- Partner compromise
- Trust propagation
- Contracts and monitoring

Critical Trap

Federated trust amplifies risk from partners.

Q360: Security Metrics Balance

Question

Which metric combination BEST reflects security program health?

A. Only number of incidents

B. Mix of risk reduction, control effectiveness, and outcome metrics

C. Only budget

D. Only training completion

Q360: Explanation

Correct Answer: B

Balanced metrics:

- Risk reduction
- Control effectiveness
- Outcomes

Critical Trap

Balanced metrics tell the real story.

Q361: Alert Prioritization

Question

How should security alerts be prioritized?

A. Alphabetically

B. By business impact and asset criticality

C. By age

D. By tool

Q361: Explanation

Correct Answer: B

Business impact drives priority:

- Business impact
- Asset criticality
- Alert context

Critical Trap

Prioritize by impact, not by ticket age.

Q362: Threat Hunting Hypothesis

Question

What starts a threat hunt?

A. Marketing

B. A hypothesis based on threat intel or anomalies

C. Random scanning

D. Vendor discount

Q362: Explanation

Correct Answer: B

Hypothesis-driven:

- Hypothesis
- Intel-driven
- Anomalies

Critical Trap

Hunting is not random; it is targeted.

Q363: Threat Intel Validation

Question

Why should threat intelligence indicators be validated?

A. Marketing

B. False positives and stale data cause unnecessary blocks and alert fatigue

C. Cheaper

D. Faster

Q363: Explanation

Correct Answer: B

Validate before blocking:

- False positives
- Stale indicators
- Business disruption risk

Critical Trap

Unvalidated intel harms business.

Q364: IR Tabletop Content

Question

What should an IR tabletop exercise cover?

A. Only technology
B. Decision-making, communications, roles, and escalation
C. Only backups
D. Only vendor contacts

Q364: Explanation

Correct Answer: B

Cover decisions and comms:

- Decisions
- Communications
- Roles
- Escalation

Critical Trap

Tabletop tests decisions, not just technology.

Q365: Post-Incident Accountability

Question

What should accompany post-incident action items?

A. Blame

B. Named owners and due dates

C. Budget increase

D. Marketing

Q365: Explanation

Correct Answer: B

Owners and dates:

- Owners
- Due dates
- Tracking

Critical Trap

Actions without owners are wishes.

Q366: Forensic Chain of Custody

Question

What does chain of custody provide?

A. Marketing

B. Documented evidence integrity from collection to presentation

C. Cheaper

D. Faster

Q366: Explanation

Correct Answer: B

Custody preserves admissibility:

- Documented integrity
- Admissibility
- Regulatory support

Critical Trap

Broken chain of custody loses evidence.

Q367: Vendor Breach Response

Question

What should be done IMMEDIATELY after a vendor notifies of a breach?

A. Terminate the vendor

B. Verify scope, impact, and applicable notification requirements

C. Blame

D. Ignore

Q367: Explanation

Correct Answer: B

Verify and respond:

- Verify scope
- Assess impact
- Regulatory notification

Critical Trap

Vendor breach is your breach to manage.

Q368: Patch Prioritization

Question

Which patch should be prioritized?

A. Oldest patch
B. Known exploited vulnerability on an internet-facing critical system
C. Newest patch
D. Vendor preferred

Q368: Explanation

Correct Answer: B

Exploited critical:

- Known exploited
- Internet-facing
- Critical asset

Critical Trap

Priority = exploitability times impact.

Q369: Secure Baseline Drift

Question

What is configuration drift and why does it matter?

- A Marketing
- B Systems diverge from secure baseline, creating exposure
- C Faster
- D Smaller

Q369: Explanation

Correct Answer: B

Drift creates exposure:

- Divergence
- Detection
- Remediation

Critical Trap

Configuration drift is silent risk.

Q370: Backup vs Archive Retention

Question

Which retention policy applies to backups versus archives?

A. Same

B. Backup retention is short-term; archive retention follows regulatory requirements

C. Archive short-term

D. Neither

Q370: Explanation

Correct Answer: B

Different retention:

- Backup retention short
- Archive follows regulation
- Distinguish policies

Critical Trap

Backups and archives have different retention.

Q371: Immutable Logs Risk

Question

What is a trade-off of immutable logs?

- A Slower search
- B Storage cost growth; sensitive data persists in logs
- C Cheaper
- D Faster

Q371: Explanation

Correct Answer: B

Storage and sensitive data:

- Storage growth
- Sensitive data persists
- Retention policies

Critical Trap

Immutable logs accumulate data; retention management matters.

Q372: Key Rotation Frequency

Question

How should key rotation frequency be determined?

A. Never rotate

B. Based on crypto period, data sensitivity, and regulatory requirements

C. Once per year only

D. Vendor preference

Q372: Explanation

Correct Answer: B

Risk-based rotation:

- Crypto period
- Sensitivity
- Regulation

Critical Trap

Rotation frequency is risk and regulator driven.

Q373: HSM Availability Risk

Question

What is the PRIMARY risk of a single HSM without high availability?

A. Cheaper

B. HSM failure can halt cryptographic operations and services

C. Slower

D. Smaller

Q373: Explanation

Correct Answer: B

HA matters:

- Crypto becomes unavailable
- Service outage
- HA design

Critical Trap

Single HSM is a single point of failure.

Q374: TLS Version

Question

Which TLS version should be avoided?

A. TLS 1.3
B. TLS 1.0 and 1.1
C. TLS 1.2
D. All versions

Q374: Explanation

Correct Answer: B

Old TLS deprecated:

- TLS 1.0 and 1.1 deprecated
- Use TLS 1.2 or 1.3
- Disable weak versions

Critical Trap

TLS 1.0 and 1.1 are insecure.

Q375: Certificate Renewal Monitoring

Question

Why is certificate renewal monitoring critical?

A. Marketing

B. Prevent outages from expiring certificates and detect unauthorized changes

C. Cheaper

D. Faster

Q375: Explanation

Correct Answer: B

Expiry causes outages:

- Expiry causes outages
- Monitoring alerts
- Renewal plan

Critical Trap

Expired certificates break services.

Q376: HSM vs TPM

Question

What is the main difference between HSM and TPM?

A. Identical

B. TPM is embedded in device for device identity; HSM is dedicated to server or enterprise key management

C. TPM is for servers only

D. HSM is for laptops

Q376: Explanation

Correct Answer: B

Device vs enterprise:

- TPM in endpoint devices
- HSM in server or enterprise
- Different scale

Critical Trap

TPM is per-device; HSM is enterprise-grade.

Q377: Access Recertification Ownership

Question

Who should approve access recertification?

A. IT

B. Business managers who know the user's role

C. Auditor

D. Vendor

Q377: Explanation

Correct Answer: B

Business managers know roles:

- Business managers
- Knowing role
- Accountability

Critical Trap

Recertification is a business decision.

Q378: Least Privilege Violation

Question

What is the PRIMARY risk of granting excessive privileges?

A. Marketing
B. Blast radius of misuse or compromise
C. Cheaper
D. Faster

Q378: Explanation

Correct Answer: B

Blast radius grows:

- Blast radius grows
- Misuse impact
- Compromise impact

Critical Trap

Excessive privilege magnifies impact.

Q379: Privacy by Design Benefit

Question

What is a benefit of privacy by design?

A. Higher cost

B. Cheaper remediation later and improved trust

C. Slower

D. More audits

Q379: Explanation

Correct Answer: B

Early design cheaper:

- Cheaper later
- Improved trust
- Compliance built in

Critical Trap

Privacy by design saves cost and builds trust.

Q380: DSAR Refusal Documentation

Question

What should be documented when refusing a data subject request?

A. Nothing

B. The legal basis and communication to the data subject

C. Marketing

D. Budget

Q380: Explanation

Correct Answer: B

Document refusal basis:

- Legal basis
- Clear communication
- Records

Critical Trap

Refusals need documented basis.

Q381: HIPAA Safeguards

Question

Which are HIPAA safeguard categories?

A. Marketing
B. Administrative, physical, and technical safeguards
C. Only technical
D. Only physical

Q381: Explanation

Correct Answer: B

Three safeguard types:

- Administrative
- Physical
- Technical

Critical Trap

HIPAA security requires all three safeguard types.

Q382: CCPA Verification

Question

What is a key requirement for CCPA consumer requests?

A. Instant response

B. Verify the consumer and provide a reasonable response process

C. Ignore

D. Marketing

Q382: Explanation

Correct Answer: B

Verify and respond:

- Verify consumer
- Reasonable process
- Documented handling

Critical Trap

CCPA requests require verification.

Q383: Encryption Algorithm Choice

Question

Which encryption algorithm is considered strong today?

A. DES
B. AES-256
C. RC4
D. MD5

Q383: Explanation

Correct Answer: B

AES-256 strong:

- AES-256 recommended
- DES, RC4 deprecated
- MD5 is a hash

Critical Trap

DES and RC4 are outdated.

Q384: Signature vs MAC

Question

What is the main difference between a digital signature and a MAC?

- A Identical
- B Signature uses asymmetric keys and provides non-repudiation; MAC uses shared key only
- C MAC uses asymmetric
- D Both provide non-repudiation

Q384: Explanation

Correct Answer: B

Signature vs MAC:

- Signature asymmetric
- MAC symmetric
- Only signature gives non-repudiation

Critical Trap

MAC cannot provide non-repudiation.

Q385: Security Training Metrics

Question

Which training metric is MOST useful?

- A Completion rate
- B Behavior change such as phishing reports and reduced clicks
- C Number of slides
- D Hours trained

Q385: Explanation

Correct Answer: B

Behavior beats completion:

- Behavior metrics
- Phishing reports
- Reduced clicks

Critical Trap

Completion alone does not equal awareness.

Q386: Whaling Indicators

Question

Which is a hallmark of a whaling attack?

A. Mass phishing
B. Highly personalized messages targeting executives
C. Marketing
D. Only spam

Q386: Explanation

Correct Answer: B

Highly targeted:

- Personalized
- Executives targeted
- Spear phishing variant

Critical Trap

Whaling is highly targeted.

Q387: Board Tabletop Outcome

Question

Which outcome is MOST valuable from a board cyber tabletop?

A. Slide count
B. Clarity of decision rights and crisis communication expectations
C. Marketing
D. Budget

Q387: Explanation

Correct Answer: B

Clarity of roles:

- Decision rights
- Communication clarity
- Board roles

Critical Trap

Board tabletops clarify crisis roles.

Q388: Middleware Patch Risk

Question

Why is unpatched middleware high-risk?

A. Cheap

B. Sits between tiers and exposes high-value systems if compromised

C. Slower

D. Bigger

Q388: Explanation

Correct Answer: B

High-value position:

- Middle tier
- Broad impact
- High-value position

Critical Trap

Middleware vulnerabilities have amplified impact.

Q389: Secret Storage Practice

Question

Which is the best practice for secret storage?

A. Hardcode
B. Secrets manager with rotation and audit
C. Email
D. Shared document

Q389: Explanation

Correct Answer: B

Secrets manager:

- Central storage
- Rotation
- Audit

Critical Trap

Hardcoded secrets are a breach risk.

Q390: Continuous Compliance Value

Question

What is the main value of continuous compliance?

A. Marketing

B. Detects drift and non-compliance faster than periodic audits

C. Cheaper

D. Faster

Q390: Explanation

Correct Answer: B

Continuous detection:

- Faster detection
- Drift remediation
- Continuous assurance

Critical Trap

Continuous compliance closes audit gaps.

Q391: CAIQ Limitations

Question

What is a limitation of CAIQ?

- A Independent audit
- B Self-assessment may be biased or inaccurate
- C Legal evidence
- D Regulatory filing

Q391: Explanation

Correct Answer: B

Self-reported:

- Self-reported
- Bias risk
- Independent audits stronger

Critical Trap

CAIQ is not independent assurance.

Q392: SaaS Misconfiguration Prevention

Question

What reduces SaaS misconfiguration risk?

A. Nothing

B. Continuous configuration monitoring and least privilege defaults

C. Vendor branding

D. More users

Q392: Explanation

Correct Answer: B

Monitor configurations:

- Configuration monitoring
- Least privilege
- User training

Critical Trap

Misconfigurations are the top SaaS risk.

Q393: Cloud IAM MFA

Question

Why is MFA essential for cloud IAM?

A. Marketing

B. Prevents credential compromise and unauthorized access to cloud resources

C. Cheaper

D. Faster

Q393: Explanation

Correct Answer: B

MFA blocks credential abuse:

- Prevents credential theft
- Requires second factor
- Reduces cloud account takeover

Critical Trap

Cloud without MFA is highly risky.

Q394: Cloud Encryption Key Control

Question

What does BYOK provide in cloud encryption?

A. Marketing

B. Customer-controlled key material with provider-managed operations

C. Free tier

D. Unlimited storage

Q394: Explanation

Correct Answer: B

BYOK keeps key control:

- Bring your own key
- Control key material
- Provider operations

Critical Trap

BYOK improves key control.

Q395: Cloud Data Loss Prevention

Question

Which control helps prevent accidental cloud data deletion?

A. Marketing

B. Versioning, soft delete, and least privilege

C. Cheaper

D. Faster

Q395: Explanation

Correct Answer: B

Versioning and soft delete:

- Versioning
- Soft delete
- Least privilege

Critical Trap

Cloud data loss is often customer-caused.

Q396: Security Metrics Context

Question

What makes security metrics valuable to executives?

A. Raw counts

B. Business context and risk appetite comparison

C. Technical jargon

D. Marketing

Q396: Explanation

Correct Answer: B

Business context:

- Business context
- Appetite comparison
- Actionable insights

Critical Trap

Executives need context, not raw data.

Q397: Security Risk Acceptance

Question

Who should sign off on a residual security risk that exceeds appetite?

A. Security team
B. Board or delegated authority
C. Vendor
D. Auditor

Q397: Explanation

Correct Answer: B

Board-level for high risk:

- Board or delegated authority
- Documented
- Time-bound

Critical Trap

Above-appetite acceptance requires high authority.

Q398: Program Maturity Indicators

Question

Which is a key indicator of program maturity?

A. More tools
B. Risk-based decisions, metrics, and continuous improvement
C. Larger budget
D. Fewer incidents

Q398: Explanation

Correct Answer: B

Maturity is outcomes:

- Risk-based
- Measured
- Improving

Critical Trap

Maturity is continuous improvement.

Q399: Security Continuous Cycle

Question

Why is security described as continuous?

- A Marketing
- B Threats and business change require ongoing risk management
- C One-time project
- D Purchase

Q399: Explanation

Correct Answer: B

Continuous risk management:

- Threats change
- Business changes
- Ongoing

Critical Trap

Security is a continuous process, not a project.

Q400: Ultimate Security Truth

Question

What is the ultimate truth about security risk?

A. Can be eliminated

B. Risk is managed to acceptable levels and accepted by owners

C. One-time decision

D. Optional

Q400: Explanation

Correct Answer: B

Risk managed, not eliminated:

- Managed to acceptable levels
- Accepted by owners
- Continuous

Critical Trap

Risk cannot be eliminated; it can be managed.

Exam Mindset Summary

Remember

- **CIA triad:** Confidentiality, Integrity, Availability
- **IAAA:** Identification, Authentication, Authorization, Accountability
- **Encryption is reversible; hashing is one-way**
- **Signatures** provide integrity, authenticity, non-repudiation
- **Privacy** is rights; **security** is protection
- **Zero Trust:** verify every access
- **Cloud:** shared responsibility; data location matters
- **Maturity:** continuous improvement and metrics
- **Security is continuous risk management**

Thank You

Good Luck on Your CRISC Exam!